

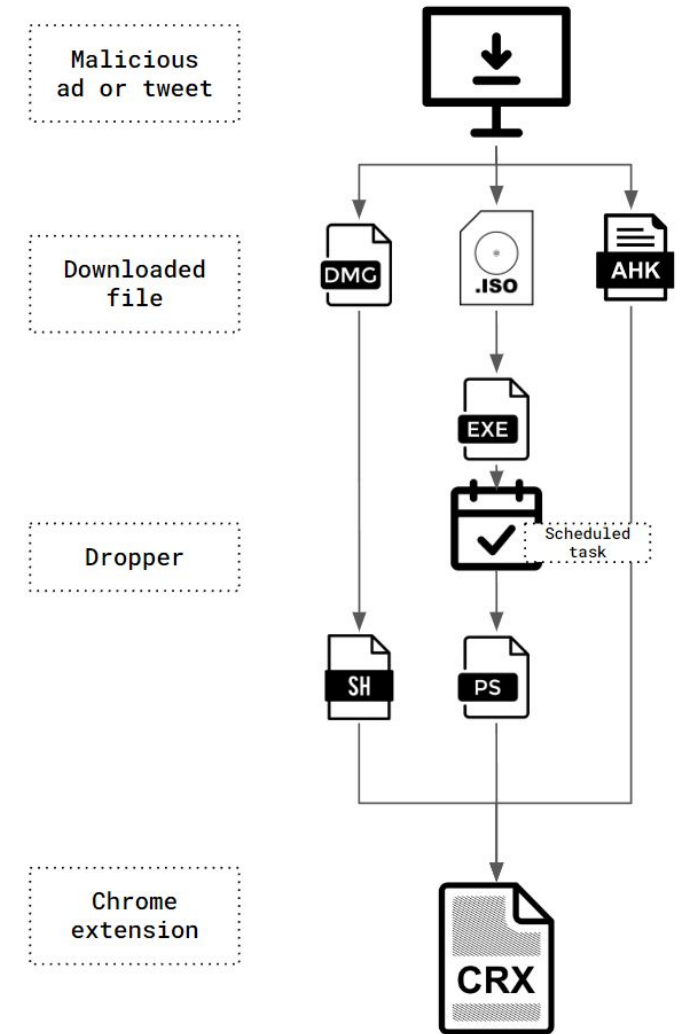
Cyber Investigation

Yihao Lim

Malware Leads to More Malware

The reason one piece of malware often downloads another is due to Modular Design and Specialization. This is often referred to as a "Dropper" or "Downloader" strategy.

- **Small Footprint:** Initial malware (the Dropper) is designed to be tiny and simple so it can bypass basic antivirus detection. Its only job is to get inside and open a "door."
- **Privilege Escalation:** The first malware might not have the permissions needed to steal data. It will download a second module specifically designed to gain administrative rights.
- **Payload Customization:** Once the attacker knows what kind of system they have infected (e.g., a high-value corporate server vs. a home laptop), they can "push" specific malware to that machine, such as ransomware for a business or a keylogger for an individual.
- **Persistence and Redundancy:** If the primary malware is detected and deleted, a secondary, hidden piece of malware (a "persistent downloader") remains behind to reinstall the attack tools later.



ChromeLoader is a multi-stage malware family. Each variant contains different stages throughout its infection chain, but the infection chain often looks quite similar among the different variants, including malicious browser extensions used in all variants.

Indicators of Compromise (IOCs)

- In the world of cybersecurity, an Indicator of Compromise (IoC) is essentially digital "forensic evidence" that a system or network has been breached. Think of it like a broken window or a muddy footprint left behind at a crime scene; it's a sign that an intruder was there, even if you didn't see them enter.
- Security professionals use IoCs to detect ongoing attacks, investigate past breaches, and strengthen defenses against future threats.

Common Types of Indicators

IoCs are generally categorized based on where they are found:

- **Network-Based IoCs:**
 - Unusual Outbound Traffic: Large amounts of data leaving the network at 3:00 AM.
 - Unknown IP Addresses: Connections to servers in geographic locations where your company doesn't do business.
 - Domain Names: Communication with URLs known to host malware or "Command & Control" centers.
- **Host-Based IoCs (On the computer itself):**
 - File Hashes: The presence of a file with a specific SHA-256 hash known to belong to ransomware.
 - Registry Changes: New, suspicious entries in the Windows Registry that allow malware to restart automatically.
 - Unauthorized New Accounts: The sudden creation of an "Admin" account that no one authorized.

Indicators of Compromise (IOCs)



Indicators of Compromise (IOCs)

A classic and powerful example of how sharing Indicators of Compromise (IoCs) saved thousands of organizations is the response to the 2021 Microsoft Exchange Server Breach (Hafnium).

In this case, the rapid "crowdsourcing" of digital evidence turned a massive zero-day disaster into a manageable recovery effort.

Case Study: The Hafnium Microsoft Exchange Breach (2021)

1. The Incident (Company A's Discovery)

In early 2021, a cybersecurity firm called Volexity noticed strange activity on a client's server. They discovered that attackers (later dubbed "Hafnium") were using unknown vulnerabilities to break into Microsoft Exchange servers.

The Discovery: Volexity didn't just find the hole; they identified specific IoCs:

- Web Shell Names: Specific filenames like discover.aspx being created in unusual folders.
- IP Addresses: A list of servers in specific regions that were controlling the hacked machines.
- User-Agent Strings: Unique identifiers used by the attacker's browser tools.

Indicators of Compromise (IOCs)

Case Study: The Hafnium Microsoft Exchange Breach (2021)

2. The Sharing Phase

- Volexity immediately shared these findings with Microsoft and the CISA (Cybersecurity and Infrastructure Security Agency).
- CISA then published a "Cybersecurity Advisory" that contained hundreds of these IOCs in a standardized format (called STIX/TAXII) so they could be read by automated security software worldwide.

3. The Protection (Company B's Defense)

Imagine Company B, a small hospital that hadn't been attacked yet. They didn't have the advanced team to find a zero-day exploit, but because the IOCs were shared:

- Their firewall automatically updated to block the IP addresses used by Hafnium.
- Their antivirus ran a scan specifically looking for the file hashes of the "web shells" identified by Volexity.
- The Result: Even though the hospital was still technically "vulnerable" (because they hadn't installed the software patch yet), the attackers couldn't get in because their "tools and footprints" were already blacklisted.

Log File Analysis Walkthrough

- IP Address and host name
- Country or region of origin
- Browser and operating system used
- Direct access by the user or reference from another website or advertising measure
- Type of search engine and search term entered
- Duration and number of pages visited by the user
- Page on which the user has left the website again



Why is Log Analysis Important?

Log analysis is the process of reviewing computer-generated event logs to proactively identify bugs, security threats or other risks. Log analysis can also be used more broadly to ensure compliance with regulations or review user behavior.

By regularly analyzing logs, you can identify unusual activities that could signal a potential security threat. For instance, multiple failed login attempts from a single IP address could indicate a brute force attack.

What is a log file?

Anything that stores data for a system – examples are:

- The operating system used by the user or client
- The browser used
- The time and date of access
- Commands requested by the server
- The protocol, e.g. https
- The number of bytes transferred
- The URL previously called up by the user
- The server's response
- The file name and the file path
- The IP address or DNS address

Use cases include:

- To comply with internal security policies and outside regulations and audits
- To understand and respond to data breaches and other security incidents
- To troubleshoot systems, computers, or networks
- To understand the behaviours of your users
- To conduct forensics in the event of an investigation

A log is a comprehensive file that captures activity within the operating system, software applications or devices. The log file automatically documents any information designated by the system administrators, including: messages, error reports, file requests, file transfers and sign-in/out requests. The activity is also timestamped, which helps IT professionals and developers establish an audit trail in the event of a system failure, breach or other outlying event.

What to Look out for during Log Analysis?

- **Pattern detection and recognition:** Understanding patterns in your data can help you detect anomalies.
- **Normalization:** to convert different log elements such as dates to the same format.
- **Tagging and classification:** to tag log elements with keywords and categorize them into a number of classes so you can filter and adjust the way you display your data.
- **Correlation analysis:** to collate logs from different sources and systems and sort meaningful messages that pertain to a particular event. Correlation analysis helps discover connections between data not visible in a single log, especially since there are usually multiple records of a security incident.
 - For instance, if you have just experienced a cyber attack, correlation analysis would put together the logs generated by your servers, firewalls, network devices, & other sources, and find the messages that are relevant to that particular attack. This process is often associated with alerting, as the data you gather from correlation analysis can help you craft alerts when certain patterns in the logs arise.
- **Artificial ignorance:** a machine learning process to identify and “ignore” log entries that are not useful and detect anomalies. Artificial ignorance will ignore routine log messages such as regular system updates but allow for new or unusual messages to be detected and flagged for investigation. Artificial ignorance can also alert you about routine events that should have happened but did not.

Useful Tools for IOC Investigation



Analyse suspicious files, domains, IPs and URLs to detect malware and other breaches, automatically share them with the security community

FILE

URL

SEARCH



[No Title]

URL, IP address, domain, or file hash

By submitting data above, you are agreeing to our [Terms of Service](#) and [Privacy Policy](#), and to the **sharing of your Sample submission with the security community**. Please do not submit any personal information; VirusTotal is not responsible for the contents of your submission. [Learn more](#).

① Want to automate submissions? [Check our API](#), free quota grants available for new file uploads

The VirusTotal Ecosystem: From Analysis to Actionable Intelligence

Analysis & Intelligence

Advanced Search Intelligence

Search modifiers...



Files

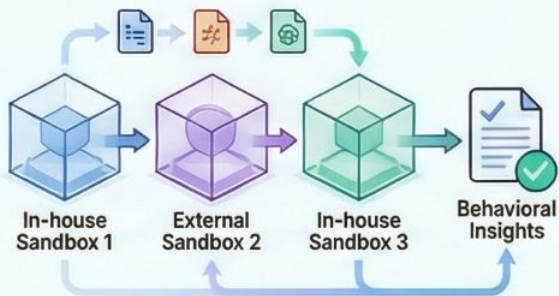
IPs

Domains

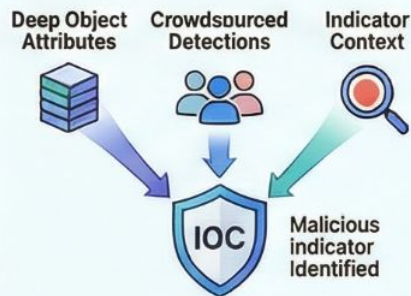
URLs



Behavioral Sandboxing



IOC Reputation & Enrichment



Core Scanning & Searching Entities



Files

- YARA rules
- VTgrep content search
- Similarity matching



Infrastructure

- IP address
- Domain
- URL reputation
- Relationship tracking



Crowdsourced

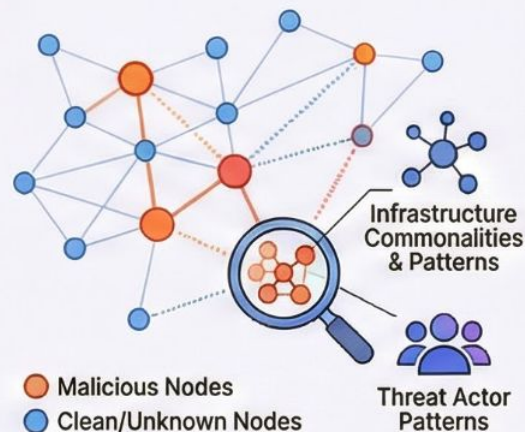
- Community-driven Sigma rules
- IDS rules
- YARA dashboards

Proactive Hunting & Investigation

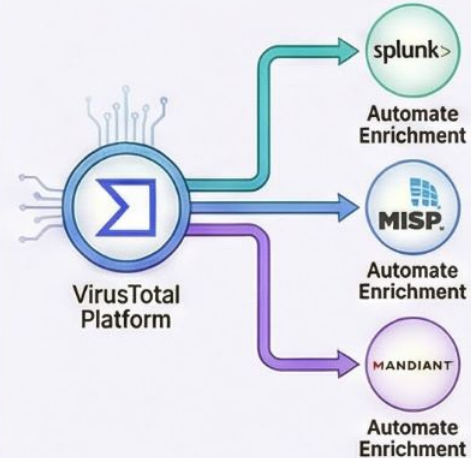
Continuous Threat Hunting



Visual Investigation with VT Graph



Enterprise-Grade Integrations



How VT Works

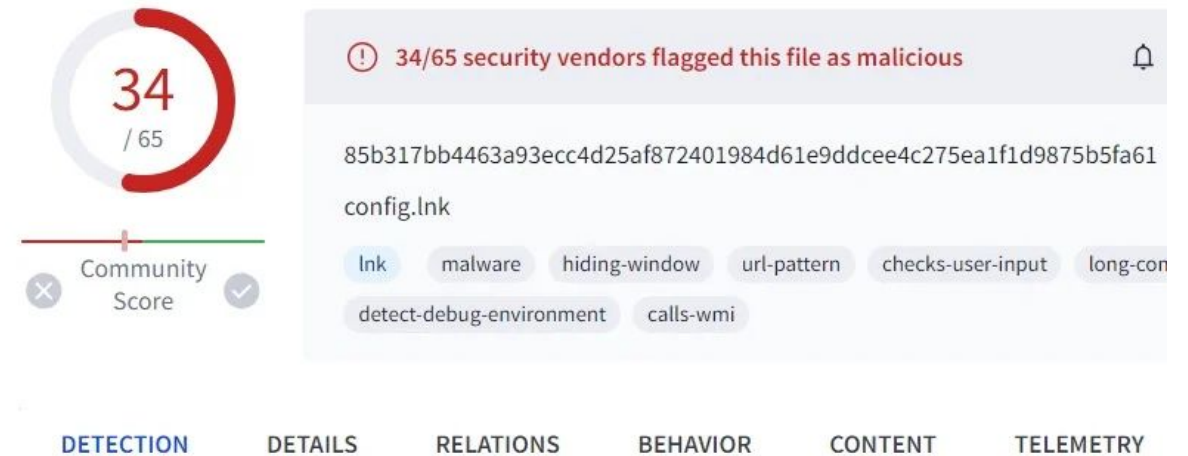
VirusTotal inspects items with over 70 antivirus scanners and URL/domain blocklisting services, in addition to a myriad of tools to extract signals from the studied content. **Any user can select a file from their computer using their browser and send it to VirusTotal.**

- As with files, URLs can be submitted via several different means including the VirusTotal webpage, browser extensions and the API.
- Upon submitting a file or URL basic results are shared with the submitter, and also between the examining partners, who use results to improve their own systems.
- As a result, by submitting files, URLs, domains, etc. to VirusTotal you are contributing to raise the global IT security level.

This core analysis is also the basis for several other features, including the VirusTotal Community: a network that allows users to comment on files and URLs and share notes with each other.

VirusTotal can be useful in detecting malicious content and also in identifying false positives -- normal and harmless items detected as malicious by one or more scanners.

The VirusTotal Interface



The VirusTotal GUI is the web interface of the platform. To query VirusTotal using the GUI, users enter a search query into the search field. A search query is composed of one or multiple search filters.

- A search filter can be a value uniquely identifying a submitted artifact – a URL, domain, file hash (MD5, SHA-1, or SHA-256), or an IP address. This filter cannot be combined with other filters and is used for retrieving information related to only a single submitted artifact.
- When a user inputs a value, VirusTotal retrieves the corresponding artifact and related information from its dataset and displays this data to the user as a web analysis report.
- To retrieve the artifact and its related information, VirusTotal searches its dataset for an object that has an ID or an attribute (for MD5 or SHA-1 hashes) that matches the user-provided value. The platform also explores relationships to and from this object.

Search Modifiers

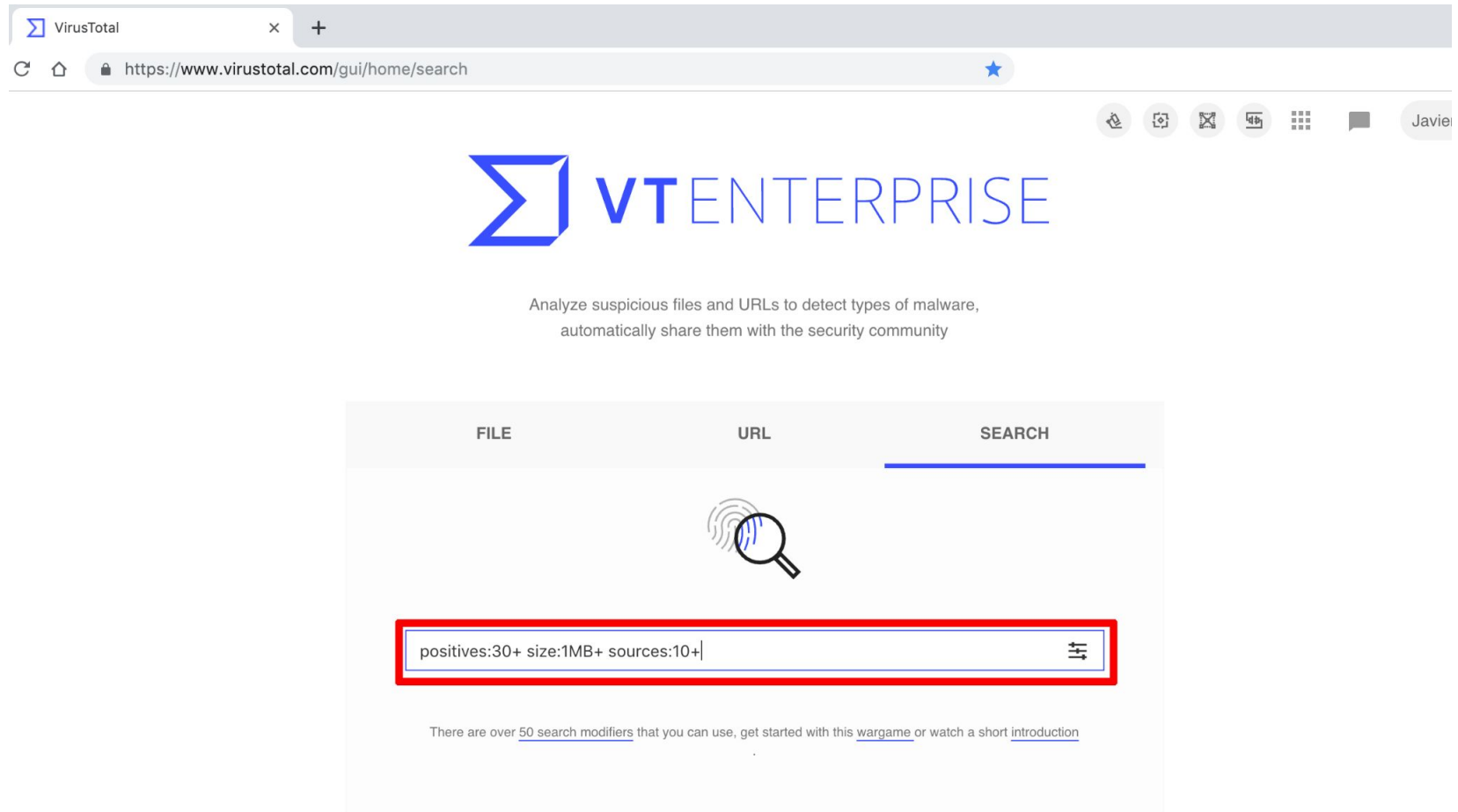
There are a set of special terms that you can use to refine your search results.

For example, you can take advantage of the term [positives:5+](#) to get files detected by five antivirus solutions or more. If you want to get those detected by ten engines or less you can use [positives:11-](#) .

Specifying the number without any trailing plus or minus sign you will retrieve those detected exactly by the given number of engines, i.e. [positives:7](#).

These terms can be used more than once in the same query, for example [positives:20+](#) [positives:31-](#) will return any file detected by a number of engines in the range 20-30.

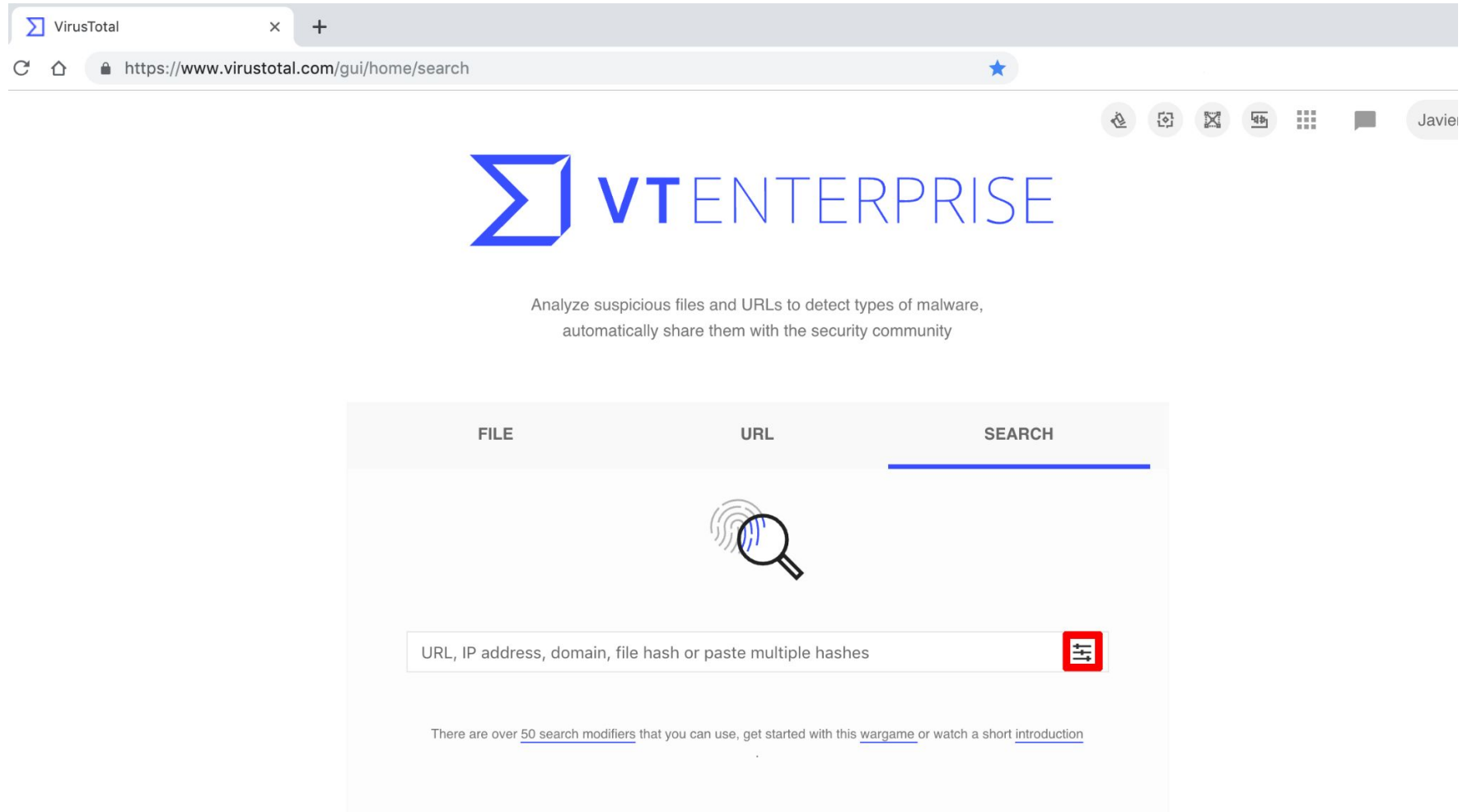
Search Modifiers



The screenshot shows the VirusTotal Enterprise web interface. At the top, the browser address bar displays the URL `https://www.virustotal.com/gui/home/search`. The page features the "VT ENTERPRISE" logo and a description: "Analyze suspicious files and URLs to detect types of malware, automatically share them with the security community". Below this, there are three tabs: "FILE", "URL", and "SEARCH", with the "SEARCH" tab being the active one. A magnifying glass icon is positioned above a search input field. The input field contains the text `positives:30+ size:1MB+ sources:10+` and is highlighted with a red rectangular border. To the right of the input field is a small icon for sorting or filtering. Below the search bar, a note states: "There are over [50 search modifiers](#) that you can use, get started with this [wargame](#) or watch a short [introduction](#)".

Search Modifiers

Or click on the sliders icon:



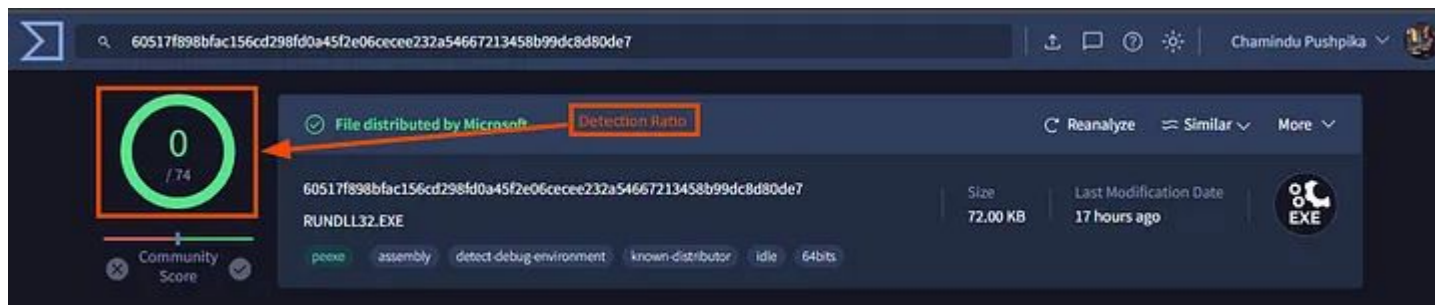
Search Modifiers

To get a form where you can use some of these modifiers:

The image shows a search interface with 15 numbered modifiers. The modifiers are: 1. File Type (dropdown), 2. Detections (dropdown), 3. Min. File size (dropdown), 4. Max. File size (dropdown), 5. Antivirus label contains... (text input), 6. Behavior report contains... (text input), 7. File metadata contains... (text input), 8. File signature contains... (text input), 9. Downloaded from... (text input), 10. File name (text input), 11. Tags (text input), 12. Last Submitted After (YYYY-MM-DDTHH:MM:SS) (text input), 13. Last Submitted Before (YYYY-MM-DDTHH:MM:SS) (text input), 14. Times Submitted (dropdown), 15. Unique Sources (dropdown). There are also 'Clear' and 'Search' buttons at the bottom right.

1. Select a file type from the dropdown list of most common file types.
2. Number of antivirus vendors that detected it upon scanning with VirusTotal.
3. Minimum file size. The size can be specified in bytes, kilobytes(default) or megabytes.
4. Maximum file size. The size can be specified in bytes, kilobytes(default) or megabytes.
5. Malware family name exclusively on the antivirus results (no matter which particular engine produced the output). Example: "Trojan.Isbar" to search for malware with this family name.
6. Executable files (for example: pexe, dmg, apks) whose dynamic behavioral report contains the literal provided.
7. Finds all those files that have some (indexed) Exif field containing the literal(s) provided, not only limited to Exif, certain other tools apply, such as taggant packer information, office metadata, etc.
8. Finds all those files that have some sigcheck/codesign (PE signature, Apple code signing) field containing the literal(s) provided.
9. Files that have been downloaded from a URL containing the literal provided.
10. Files submitted to VirusTotal with a file name that contains the literal provided.
11. Files tagged by VirusTotal with the literal provided. Example: android , html , peexe
12. Files submitted to VirusTotal after this datetime.
13. Files submitted to VirusTotal before this datetime.
14. Number of times files were submitted to VirusTotal.
15. Number of distinct sources that submitted the file to VirusTotal, independently of whether any given source submitted the file more than once.

Investigation Sample



In the top left, is a detection ratio: the number is the number of detections as malicious out of the total number of detection engines.

One important tag to be familiar with is known-distributor. This tag is used for files that are provided to VirusTotal by a reliable source.

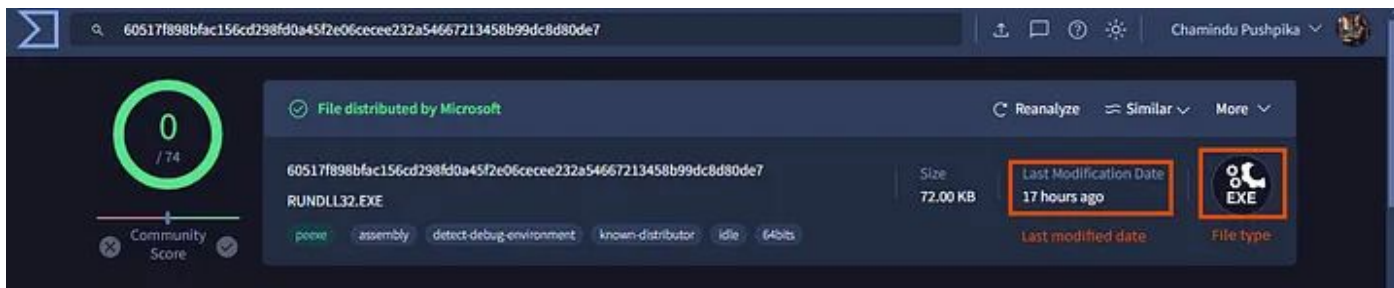


The header also contains the SHA256 hash of the file and a name for the file. This name may be the original name, internal name of the file, or the name may be the name of the first file with this hash that was uploaded.

As a result, the name here may differ from the name of the file that was uploaded.

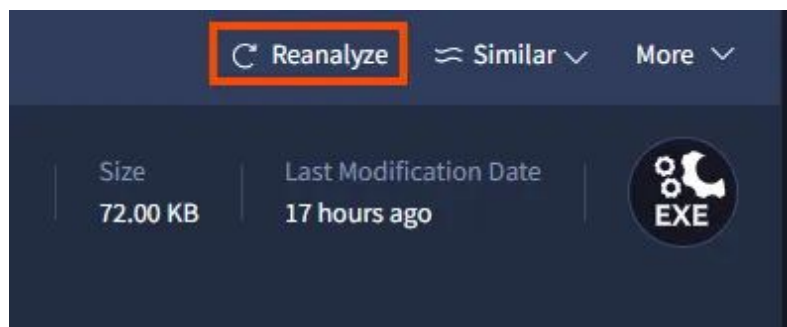
Investigation Sample

On the right side of the header, we see other details such as the file size, Last Modification Date, and file type.



The Last Modification Date refers to the last time the report was last updated. This matches the Last Analysis Date in another part of the report. You should always think of this date in the header as the last time the file was analyzed.

Users can manually trigger the file to be analyzed again by using the Reanalyze button above the last modification date.



Reanalyzing files is important in two situations:

1. First, the file appears to be old. Perhaps the file was uploaded to VirusTotal several years ago and the last analysis was also years ago. Reanalyzing the file will process the file again against new detections that may have become available since the time that the file was previously analyzed.
2. Second, the file may be very new. It is common with emerging threats that detections may not exist and VirusTotal may present the user with a low score (less than 10 detections) or even a clean score (0 detections). Reanalyzing the file will check the file against the detection engines again.

Investigation Sample

In the Details tab, under the History section, you can see the Last Analysis date.

The First Submission date is for when the file was first uploaded to VirusTotal.

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 2

Basic properties ⓘ

MD5

SHA-1

SHA-256

Vhash

Authentihash

Imphash

Rich PE header hash

SSDEEP

TLSH

File type

Magic

TrID

DetectItEasy

Magika

File size

10f08638e7c04d15ba4b4a740087a826

07888e33210b015c0a206c60826fd40d5c3b5508

60517f898bfac156cd298fd0a45f2e06cecee232a54667213458b99dc8d80de7

074076651d151d15151cz1b1z9@z

d860ec7aa5229c6cd0219e58a2615d7148d3bdc5b9eb395348584d23aad23d94

5c68de198b5d2dd5c1129782ad19676c

ae2fc848b4281fb26872b24d1cbb94c9

1536:yRBHxEvtdRnnV2F35pCZCump2lknaAnHwfbEUCmUVR:6BRCrnipymcnQfLH4R

T17C734A1DA7B924E5E67A563984D20209E3B0F431671267FF06E0C27E2F237E1A935F84

Win32 EXE executable windows win32 pe peexe

PE32+ executable (GUI) x86-64, for MS Windows

Win64 Executable (generic) (56.5%) | Windows Icons Library (generic) (11%) | OS/2 Executable (generic) (0.0%)

PE64 | Compiler: Microsoft Visual C/C++ (19.28.29395) [LTCG/C] | Linker: Microsoft Linker

PEBIN

72.00 KB (73728 bytes)

History ⓘ

Creation Time

First Seen In The Wild

First Submission

Last Submission

Last Analysis

2040-03-02 02:49:27 UTC

2021-02-11 21:15:51 UTC

2021-06-18 09:31:41 UTC

2024-06-14 09:29:10 UTC

2024-06-29 16:25:05 UTC

The Creation time is based on the file's metadata.

Malware developers can change this date and sometimes, a weird date can be a suspicious indicator, but not always. Some types of files even default to having a certain date.

In this case, the date is later than the first seen date, which is weird, but everything else with this file checks out as OK.

The last analysis date here is useful as it helps us know how long ago the file has been analyzed in contrast to the first submission.

The Last Submission date indicates the last time the file was uploaded.If something is new and being seen by many people, you can see the Last Submission get updated each time you refresh.

Another indication of users uploading the same file is the Names section, which is just below the History section.

Names ⓘ
rundll
RUNDLL32.EXE
rundll32.exe
Acrotray.exe
Rundll32.exe
RunDll32.exe
gMvBwOoHdYIQnH
sBnPvPdJo
bincheck64.exe
f0wSs
▼

Investigation Sample

Above the History section is a Basic Properties section. This section contains a variety of file hash types. If you ever need an MD5 or SHA-1 hash, this is a good place to find it. The other hashes may become useful to you as you get familiar with other hash types.

Basic properties ⓘ	
MD5	10f08638e7c04d15ba4b4a740087a826
SHA-1	07888e33210b015c0a206c60826fd40d5c3b5508
SHA-256	60517f898bfac156cd298fd0a45f2e06cecee232a54667213458b99dc8d80de7
Vhash	074076651d151d15151cz1b1z9@z
AuthentiHash	d860ec7aa5229c6cd0219e58a2615d7148d3bdc5b9eb395348584d23aad23d94
Imphash	5c68de198b5d2dd5c1129782ad19676c
Rich PE header hash	ae2fc848b4281fb26872b24d1cbb94c9
SSDEEP	1536:yRBHxEvtdRnnV2F35pCZCump2IknaAnHwfbEUCmUVR:6BRCmipymcnQfLH4R
TLSH	T17C734A1DA7B924E5E67A563984D20209E3B0F431671267FF06E0C27E2F237E1A935F84
File type	Win32 EXE executable windows win32 pe peexe
Magic	PE32+ executable (GUI) x86-64, for MS Windows
TrID	Win64 Executable (generic) (56.5%) Windows Icons Library (generic) (11%) OS/2 Executable (generic) (10.9%) Generic Win/DOS Executable (generic) (10.9%)
DetectItEasy	PE64 Compiler: Microsoft Visual C/C++ (19.28.29395) [LTCG/C] Linker: Microsoft Linker (14.28.29395) Tool: Visual Studio (2019 version 16.0.0)
Magika	PEBIN
File size	72.00 KB (73728 bytes)

This section also provides more detail on the file type. This can be useful if the file type isn't completely clear or if you need to know more nuanced detail about the file type.

Below the Names section, there is an optional Signature Info section.

Developers can digitally sign files as evidence that the file came from them. The signature contains a hash of the file so that if the file is modified in any way, the signature will flag as Invalid indicating that the file has been tampered with.

Microsoft often signs their files, but not always. As a result, the signature can be an unreliable source of truth as to if the file is from Microsoft or not.

Signature info ⓘ	
Signature Verification	
⚠ File is not signed	
File Version Information	
Copyright	© Microsoft Corporation. All rights reserved.
Product	Microsoft® Windows® Operating System
Description	Windows host process (Rundll32)
Original Name	RUNDLL32.EXE
Internal Name	rundll
File Version	10.0.22000.1 (WinBuild.160101.0800)

Investigation Sample

In order to sign a file, a company needs to “prove” to a certificate issuer that they are a legitimate company.

This system can be abused, so it is important to take a look at the company in the certificate and determine if it makes sense with everything else you know about the file.

The file is then signed by the developer and then signed by the certificate issuer. The developer’s name is usually listed first.

Take a look at the first signer of the file with the hash:
4788925332fc6128c895b0e0736a1d7d90e3891f2abb456523cbf0c1ce
d7d1e2

(Search for that hash, and look in the Details tab)



In the Signature Info section, the File Version Information is extracted from the file itself. The copyright, product, description, original name, and other details are all controlled by the creator of the file.

Since they are controlled by the creator, they should only be trusted if you trust the file.

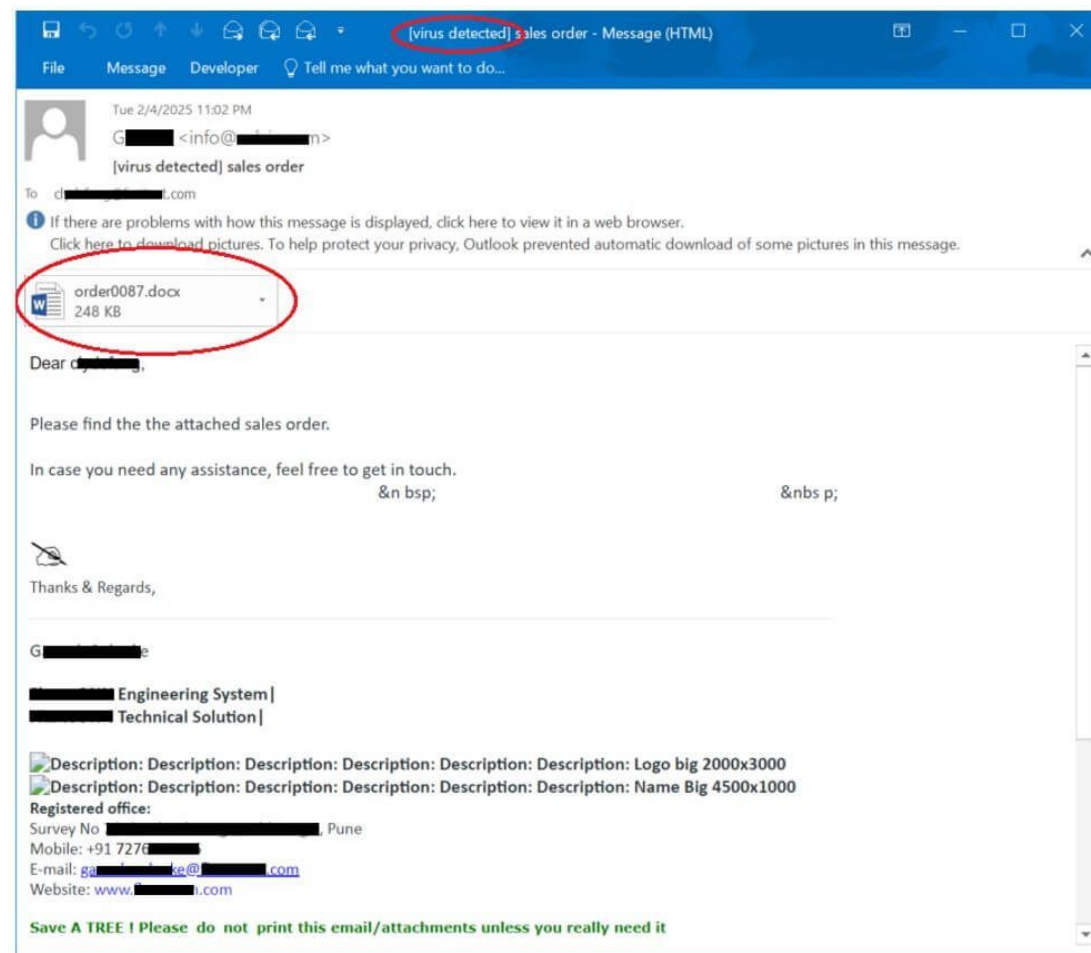
Investigation Sample

Scenario: A user reports an unexpected, suspicious email with a Word document (order0087.docx) attached.

Step 1: Initial Hash Analysis

- Extract Hash: The SOC analyst computes the hash of attachment.
- Submit to VirusTotal: The hash is pasted into the VirusTotal search bar.
- Analyze Report: The report shows a high detection ratio (e.g., 45/70 engines detect it).
- Identify Family: Detection names like FORMBOOK indicate it is a macro-based downloader.

This case study demonstrates the process of investigating a phishing email containing a malicious Word document, typical in Security Operations Center (SOC) environments.



Investigation Sample

Scenario: A user reports an unexpected, suspicious email with a Word document (invoice.doc) attached.

Step 2: Behavior Analysis (Sandboxing)

- Behavior Tab: The analyst clicks on the Behavior tab to see what the file does upon execution.
- Findings: The sandbox report reveals that invoice.doc executes powershell.exe to download a secondary payload from a specific URL.

Step 3: Network & Infrastructure Investigation

- Check IP/Domain: The downloader URL is entered into VT. The IP address resolves to a known malicious actor group, such as APT28 or similar.
- Pivot in Graph: The analyst opens the malicious URL in VT Graph.
- Discover Connections: The graph shows the IP communicates with several other malicious domains, providing a wider picture of the infrastructure

Investigation Sample

Scenario: A user reports an unexpected, suspicious email with a Word document (invoice.doc) attached.

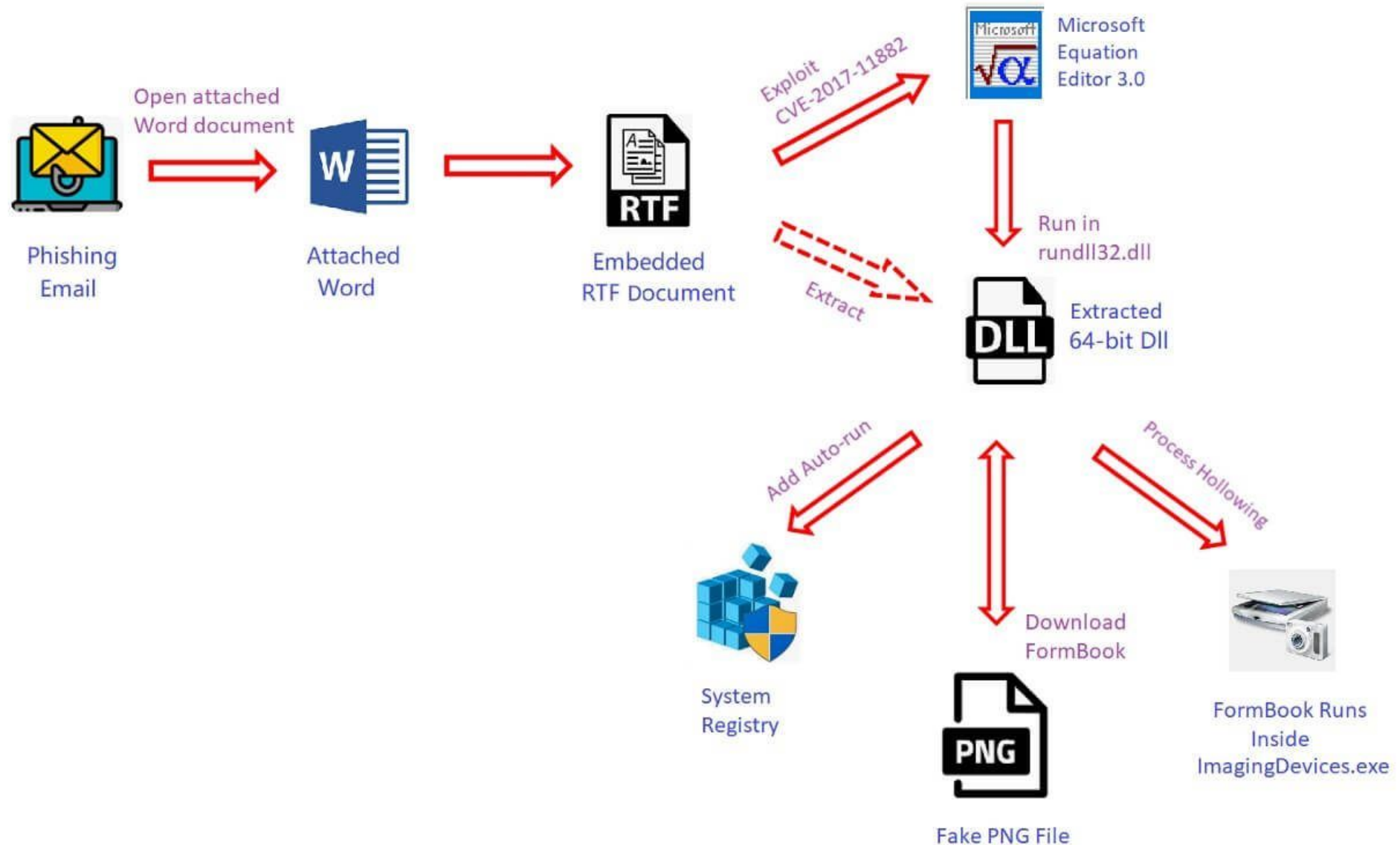
Step 4: Hunting for Related Threats

- **YARA Rules:** The analyst uses the Files section to find other samples with similar characteristics, using YARA rules provided in the report.
- **Preventive Action:** The identified malicious IPs and domains are added to the corporate firewall/proxy blacklist, preventing further infection.

Key Tips & Warnings

- **Public vs. Private:** Files uploaded to the free version of VirusTotal are shared with the security community, including antivirus vendors and researchers.
- **No Sensitive Data:** NEVER upload confidential files (e.g., sensitive corporate documents or proprietary code) to the public VT interface.
- **False Positives:** VirusTotal can sometimes flag benign files. Always check the "Community" tab and review the behavioral report to confirm, rather than relying solely on the detection ratio.
- **Alternative Tools:** For sensitive files, use VirusTotal Private Scanning or local sandboxes.

Investigation Sample: Workflow diagram of this FormBook campaign



Investigation Sample

Hi team

Our HR team received a suspicious CV “[zarina cv.docx](#),”

(MD5: ab212fc02120501429d2c5d37cc7e7e2)

please help investigate.

Regards



Analyse suspicious files, domains, IPs and URLs to detect malware and other breaches, automatically share them with the security community

FILE

URL

SEARCH



[No Title]

URL, IP address, domain, or file hash

By submitting data above, you are agreeing to our [Terms of Service](#) and [Privacy Policy](#), and to the **sharing of your Sample submission with the security community**. Please do not submit any personal information; VirusTotal is not responsible for the contents of your submission. [Learn more](#).

① Want to automate submissions? [Check our API](#), free quota grants available for new file uploads

Investigation Walkthrough

33
/ 62

Community Score

33 security vendors and no sandboxes flagged this file as malicious

Follow Reanalyze Download Similar More

a337da0d55e3f9181bfaf0171aa6dfaa943768120142c4dec984...
zarina cv.docx

Size
17.75 KB

Last Analysis Date
2 years ago

DOCX

DETECTION

DETAILS

RELATIONS

CONTENT

TELEMETRY

COMMUNITY 1

Security vendors' analysis on 2020-12-06T12:00:56 UTC

Popular threat label

trojan.ddeexec/w97m

Threat categories

trojan downloader

Family labels

ddeexec w97m office

Ad-Aware	Trojan.Downloader.DDE.Gen.1	AegisLab	Trojan.MSOffice.DdeExec.alc
Alibaba	Exploit:Office97/DDEDownloader.4ee0f...	Arcabit	Trojan.Downloader.DDE.Gen.1
Avira (no cloud)	HEUR/Downloader.DDE	Baidu	MSWord.Exploit.Agent.e
BitDefender	Trojan.Downloader.DDE.Gen.1	ClamAV	Doc.Exploit.DDEautoexec-6346603-1
Comodo	Malware@#1noe91v13ypdx	Cynet	Malicious (score: 85)
Cyren	XML/DDEDownldr.DICamelot	DrWeb	W97M.DDE.1
Emsisoft	Trojan.Downloader.DDE.Gen.1 (B)	eScan	Trojan.Downloader.DDE.Gen.1

33
/ 62

Community Score

33 security vendors and no sandboxes flagged this file as malicious

Follow Reanalyze Download Similar More

a337da0d55e3f9181bfaf0171aa6dfaa943768120142c4dec984...
zarina cv.docx

Size
17.75 KB

Last Analysis Date
2 years ago

DOCX

DETECTION

DETAILS

RELATIONS

CONTENT

TELEMETRY

COMMUNITY 1

Strings Hex Preview

Zarina Tsolaeva

Kişisel Bilgiler

Ad Soyad

Zarina Tsolaeva

Doğum Tarihi

14.09.1991

Doğum Yeri

Astana

Medeni Durumu

Bekar

Askerlik Durumu

Muaf

İletişim Bilgileri

Adres

İstanbul Zeytinburnu

Telefon

Cep

538 555 2451

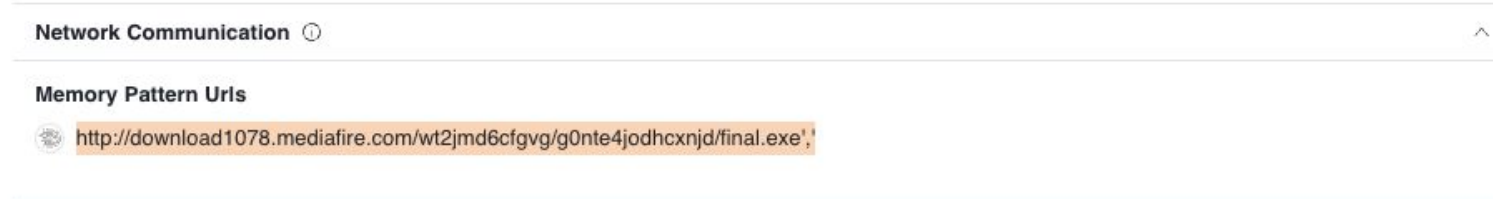
İş Deneyimi

Haziran 2017 -

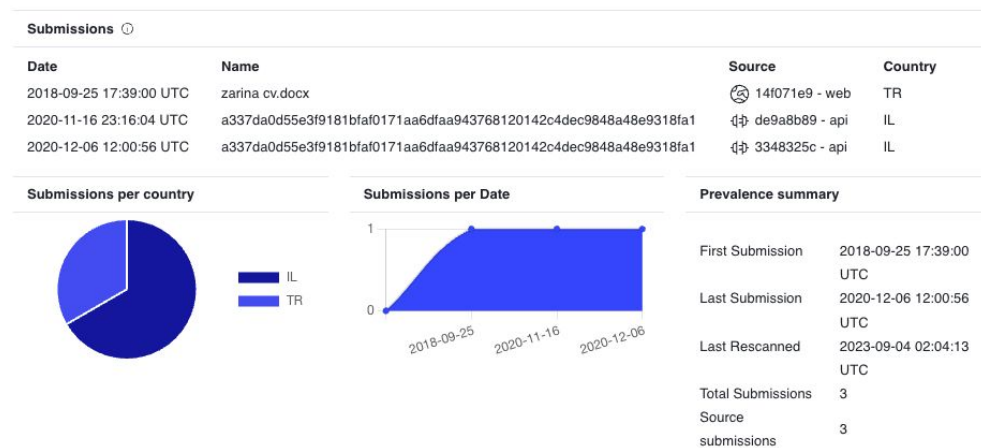
Enno İtd
Grafiker
asistan

Investigation Walkthrough

- After opening the “zarina cv.docx” file with 7-Zip, analyzed the “document.xml” file located in the “word” folder and found a carefully placed DDEAUTO command.
- The DDEAUTO command downloads a file named “final.exe” from the mediafire.com address and executes it in the TEMP folder.



- Consider if other individuals attempted to upload a similar file to VirusTotal for antivirus scanning



Investigation Walkthrough

- MITRE TTP Observations

MITRE ATT&CK Tactics and Techniques

[Open in MITRE ATT&CK Navigator](#) ^

— Execution TA0002

Exploitation for Client Execution T1203

Document is poisoned with Template scheme, through url

Dynamic Data Exchange T1559.002

Document is poisoned with DDE commands, directly or through embedded files

— Defense Evasion TA0005

Template Injection T1221

The sample has suspicious references in Office document templates to conceal malicious code or force authentication attempts.

Other Useful Features for VirusTotal

When conducting threat hunting with VirusTotal Intelligence, we can leverage more than 50 keywords.

For example, let's say we want to find records that are uploaded from Turkey (**submitter:TR**), written in Turkish language (**lang:"turkish"**), detected by more than 10 antivirus software (**positives:10**), have a docx file type (**type:docx**), and were first uploaded in 2018 (**fs:2018-01-01 T00:00:00+**).

By using these keywords, we can quickly find records that match these criteria. If we perform a similar search for xls, doc files, files containing PowerShell (**tag:powershell**), and files containing macros (**tag:macros**)

Investigation Sample

Hi team

We identified two potential malicious indicators on late Sep 2021. Can you confirm if these are associated with any threat activity?

154.223.135[.]214

012862165ec105a44fea14face53492f

Regards

DETECTION

DETAILS

RELATIONS

COMMUNITY

2

Passive DNS Replication ⓘ

Date resolved	Detections	Resolver	Domain
2021-03-24	8 / 94	VirusTotal	imap.newlylab.com

URLs ⓘ

Scanned	Detections	Status	URL
2022-04-01	1 / 93	-	http://154.223.135.214/
2022-06-12	8 / 95	404	http://imap.newlylab.com/

DETECTION

DETAILS

RELATIONS

COMMUNITY

2

Related References ⓘ

	Date	Author	Source
GhostEmperor: From ProxyLogon to kernel mode	2021-10-04	@Securelist	GhostEmperor: ...

Contained In Collections ⓘ



GhostEmperor: From ...

by AlienVaultOTX

2022-08-20 19:29:00 UTC

Domains: 11 | Files: 10 | IPs: 7 | References: 1

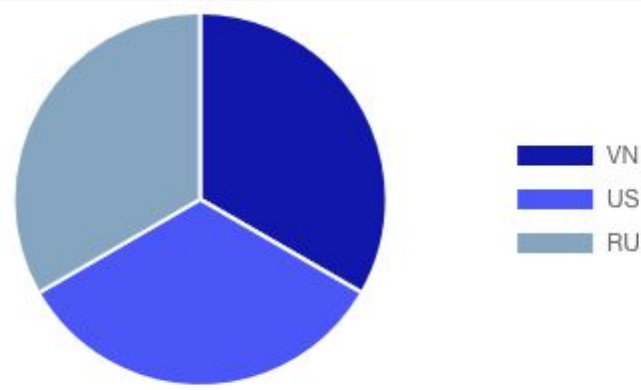
Demodex has been observed in a recent rise of attacks against Exchange servers. The malware could be used to hide and hide the source of the attack. The resp...

Investigation Sample

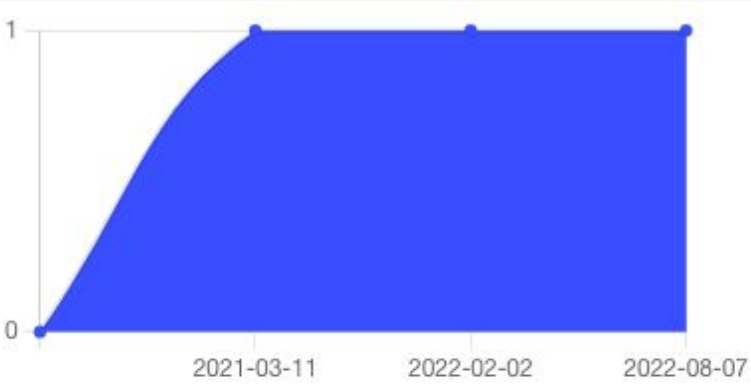
Submissions ⓘ

Date	Name	Source	Country
2021-03-11 07:42:10 UTC	Ladon8.0_all.ps1	 1df9a20b - web	VN
2022-02-02 16:54:57 UTC	unknown	 2b761cae - api	US
2022-08-07 09:36:04 UTC	2021.09.30	 2afc308b - web	RU

Submissions Per Country



Submissions Per Date

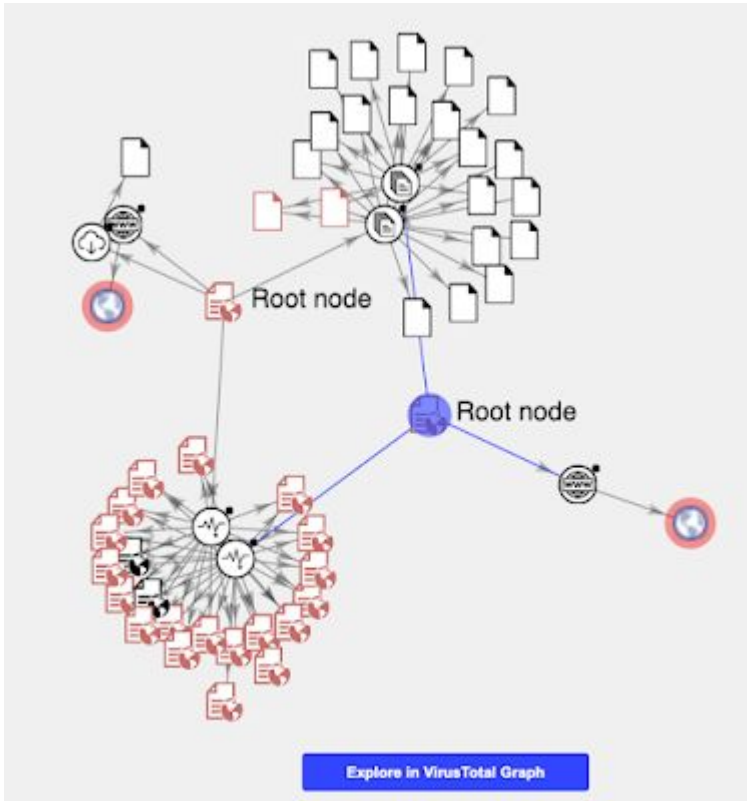


Prevalence Summary

First Submission	2021-03-11 07:42:10 UTC
Last Submission	2022-08-07 09:36:04 UTC
Last Rescanned	2022-08-22 16:08:53 UTC
First Seen In The Wild	2020-06-11 13:11:37 UTC
Total Submissions	3
Source submissions	3
End-user Sightings	Sysinternals tools

▼	•	•	file	0a208a5/036a3/90/c8c995420a6ce543ea086c4215/88eccere28bda40f9a08
▼	?	?	file	dbda894a421fe7a21d5ba5e7338fc662092909cfb32463892fca94dcb00dcdeb

Leveraging VT Graph



Another way to start our investigation would be taking advantage of VT Graph.

This would put on the table all the elements related to the IOCs we have to start our investigation with, giving us a good idea of the dimension and of the elements of interest.

The graph helps us visualize what both URLs share in common, as well as a bunch of additional ones that also share the same tracker ID. In particular, there are a couple of common javascript libraries detected as malicious by several AV vendors that look interesting for our investigation.

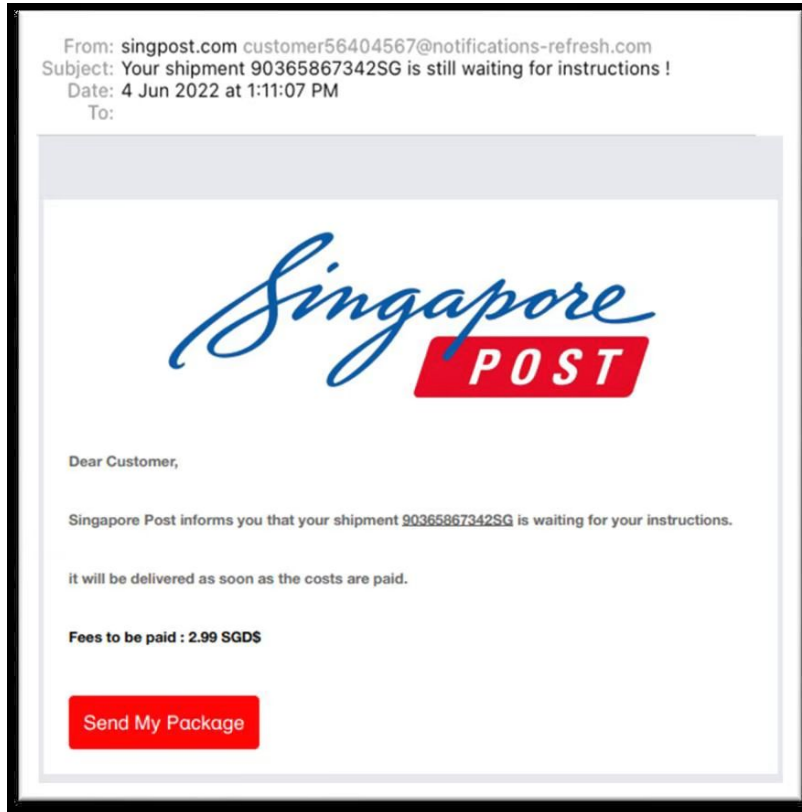
We can open their VirusTotal report in the links below:

- <https://www.virustotal.com/gui/file/a29fa70847eb0cba146b247f7d4549575b04edd588628b23a473c69c87e5c887/detection>
- <https://www.virustotal.com/gui/file/ee3f8cc642a94e667d5f885691ecbc70d5d49869d36d905d96f19391117fa084/detection>

VirusTotal Cheatsheet Link

<https://storage.googleapis.com/vtpublic/reports/VTI%20Cheatsheet.pdf>

Homework 4



Using virustotal -

look for phishing emails or malware files that targeted / impersonated Singaporean companies or Singaporean consumers **in 2025**

Investigate these emails / files, look for any malicious attachments and answer the following questions:

- Who is behind this?
- What is the motive of the threat actor?
- What information are they trying to steal?
- When did this campaign start?
- What other similar scams / campaigns are linked to your observation?

Thank You